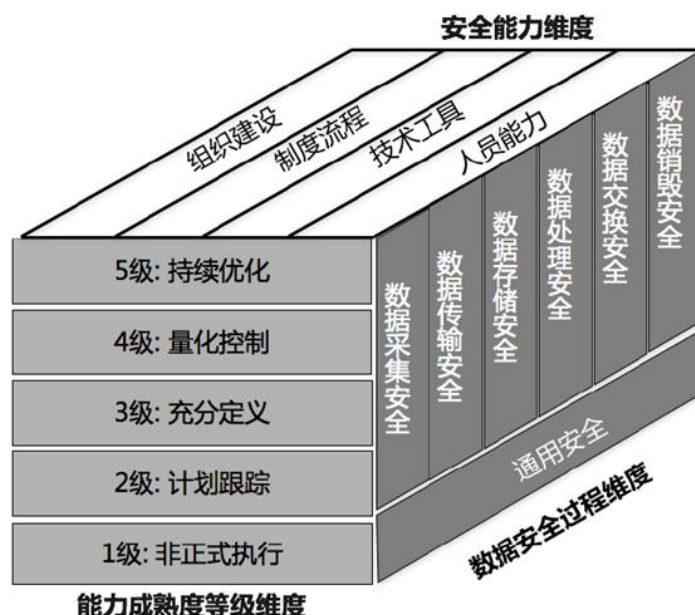


《数据安全能力成熟度模型》实践指南：数据分级分类

美创科技第 59 号安全实验室

2019 年 8 月 30 日，《信息安全技术 数据安全能力成熟度模型》（GB/T 37988-2019）简称 DSMM（Data Security Maturity Model）正式成为国标对外发布，并已于 2020 年 3 月起正式实施。

DSMM 将数据按照其生命周期分阶段采用不同的能力评估等级，分为数据采集安全、数据传输安全、数据存储安全、数据处理安全、数据交换安全、数据销毁安全六个阶段。DSMM 从组织建设、制度流程、技术工具、人员能力四个安全能力维度的建设进行综合考量。DSMM 将数据安全成熟度划分成了 1-5 个等级，依次为非正式执行级、计划跟踪级、充分定义级、量化控制级、持续优化级，形成一个三维立体模型，全方面对数据安全进行能力建设。



在此基础上，DSMM 将上述 6 个生命周期进一步细分，划分出 30 个过程域。这 30 个过程域分别分布在数据生命周期的 6 个阶段，部分过程域贯穿于整个数据生命周期。

数据生命周期安全过程域					
数据采集安全	数据传输安全	数据存储安全	数据处理安全	数据交换安全	数据销毁安全
- PA01 数据分类分级 - PA02 数据安全管理 - PA03 数据溯源及记录 - PA04 数据质量管理	- PA05 数据加密传输 - PA06 网络可用性管理	- PA07 存储介质安全 - PA08 逻辑存储安全 - PA09 数据备份和恢复	- PA10 数据脱敏 - PA11 数据访问安全 - PA12 数据正常使用 - PA13 数据处理环境安全 - PA14 数据导入导出安全	- PA15 数据共享安全 - PA16 数据发布安全 - PA17 数据接口安全	- PA18 数据销毁处置 - PA19 介质销毁处置
通用安全过程域					
- PA20 数据安全策略规范 - PA26 物理数据安全	- PA21 组织与人员管理 - PA27 监控与审计	- PA22 合规管理 - PA28 漏洞与缺陷控制	- PA23 数据资产管理 - PA29 需求分析	- PA24 数据供应链安全 - PA30 安全事件应急	PA25 元数据管理

随着《中华人民共和国数据安全法(草案)》的公布，后续 DSMM 很可能会成为该法案的具体落地标准和衡量指标，对于中国企业而言，以 DSMM 为数据安全治理思路方案选型，可以更好的实现数据安全治理的制度合规。

”

本系列文将以 DSMM 数据安全治理思路为依托，针对上述各过程域，基于充分定义级视角（3 级），提供数据安全建设实践建议，本文作为开篇，将介绍数据采集安全阶段的数据分类分级过程域（PA01）。

01 定义

DSMM 标准在充分定义级对数据分类分级要求如下：

组织建设：

组织应设立负责数据安全分类分级工作的管理岗位人员，主要负责定义组织整体的数据分类分级的安全原则（BP.01.04）。

制度流程：

- 1) 应明确数据分类分级原则、方法和操作指南（BP.01.05）；
- 2) 应对组织的数据进行分类分级标识和管理（BP.01.06）；
- 3) 应对不同类别利级别的数据建立相应的访问控制、数据加解密、数据脱敏等安全管理和控制措施（BP.01.07）；
- 4) 应明确数据分类分级变更审批流程和机制，通过该流程保证对数据分类分级的变更操作及其结果符合组织的要求(BP.01.08)。

技术工具：

应建立数据分类分级打标或数据资产管理工具,实现对数据的分类分级自动标识、标识结果发布、审核等功能(BP.01.09)。

人员能力：

负责该项工作的人员应了解数据分类分级的合规要求,能够识别哪些数据属于敏感数据(BP.01.10)。

02 实践指南

组织建设：

组织机构在条件允许的情况下应该设立一个数据分类分级部门并招募相关人员，负责公司整

体的数据分类分级工作，包括负责定义组织机构整体的数据分类分级安全原则和操作指南、推动相关指南的落地情况、建立数据分类分级审批机制、对组织机构中的进行完数据分类分级的数据进行标识和管理、对识别到的敏感数据进行脱敏处理、对数据分类分级中的重要操作进行审计和记录等。

人员能力：

针对数据分类分级岗位的相关人员，需要具备良好的数据安全风险意识，熟悉国家网络安全法律法规以及组织机构所属行业的政策和监管要求，在采集数据的过程中严格按照《网络安全法》、《个人信息安全规范》等相关国家法律法规和行业规范执行，除此之外，还需要相关人员具备良好的数据分类分级基础，了解公司内部的数据资产范围、组织架构，能够准确识别出哪些数据属于敏感数据等，同时还需要相关人员熟悉数据分类分级的合规要求，熟练掌握数据安全措施，拥有制定标准化流程或制度的经验，能够根据公司的具体情况制定出符合公司真实环境的数据分类分级原则、数据分类分级操作指南、数据分类分级管理制度、数据分类分级清单等，并推动相关要求与制度的真实落地。

落地执行性确认：

针对组织建设和对应人员能力的实际落地执行性确认，可通过内部审计、外部审计等形式以调研访谈、问卷调查、流程观察、文件调阅、技术检测等多种方式实现。

制度流程：

1) 数据分级分类原则

数据分级分类应结合实际情况，明确需求，以数据的属性为基础，遵循科学性、稳定性、实用性和扩展性原则。

❖ 科学性——按照数据的多维特征以及相互间客观存在的逻辑关联进行科学和系统化的分级分类；

❖ 稳定性——根据实际情况，以数据最稳定的特征和属性为依据指定分级分类方案；

❖ 实用性——数据的分级分类要确保每个类目下要有数据，不设没有意义的类目；

❖ 扩展性——数据分级分类方案在总体上应具有概括性和包容性，能够实现各种类型数据的分类，以及满足将来可能出现的数据类型。

2) 分级分类方法及细则

- ❖ 数据分类常用方法：按关系分类，基于业务（来源）、基于内容、基于监管等。
- ❖ 数据分级常用方法：按特性分级，基于价值（公开、内部、重要核心等）、基于敏感程度（公开、秘密、机密、绝密等）、基于司法影响范围（大陆境内、跨区、跨境等）。
- ❖ 常见公用数据分类方法：重要数据、个人及企业信息、业务数据。（重要数据指泄露可导致危害国家安全/公共利益生命财产安全/危害国家关键基础设施/扰乱市场秩序/可推论出国家秘密等的数据。）
- ❖ 个人及企业信息包含直接个人信息：以电子或者其他方式记录的能够单独或者与其他信息结合识别自然人个人身份或企业的各种信息。
- ❖ 业务数据包含：企业或公共组织从事经营活动或例行社会管理功能、事务处理等一系列活动产生的可存储的数据。

根据上述公共分类，其对应分级分别如下：

重要数据分级				
第一级： 数据受到破坏后，会对公民、法人和其他组织的合法权益造成损害，但不损害国家安全、社会秩序和公共利益	第二级： 数据受到破坏后，会对公民、法人和其他组织的合法权益产生严重损害，或者对社会秩序和公共利益造成损害但不损害国家安全	第三级： 数据受到破坏后，会对社会秩序和公共利益造成严重损害，或者对国家安全造成损害。	第四级： 数据受到破坏后，会对社会秩序和公共利益造成特别严重损害，或者对国家安全造成严重损害。	第五级： 数据受到破坏后，会对国家安全造成特别严重损害。

个人及企业信息分级

低	中	高
• 保密：非授权用户获取个人信息数据对个人或群体等造成有限的不良影响。 • 完整：个人信息数据被非法授权修改和破坏对个人或群体等造成有限的不良影响。 • 可用：合法用户使用个人信息数据被不正当拒绝对个人或群体等造成有限的不良影响。	• 保密：非授权用户获取个人信息数据对个人或群体等造成严重的不良影响。 • 完整：个人信息数据被非法授权修改和破坏对个人或群体等造成严重的不良影响。 • 可用：合法用户使用个人信息数据被不正当拒绝对个人或群体等造成严重的不良影响。	• 保密：非授权用户获取个人信息数据对个人或群体等造成灾难性的不良影响。 • 完整：个人信息数据被非法授权修改和破坏对个人或群体等造成灾难性的不良影响。 • 可用：合法用户使用个人信息数据被不正当拒绝对个人或群体等造成灾难性的不良影响。

业务数据分级

低	中	高
• 保密：非授权用户获取业务数据对组织运营、组织资产等造成有限的不良影响。 • 完整：业务数据被非法授权修改和破坏对组织运营、组织资产等造成有限的不良影响。 • 可用：合法用户使用业务数据被不正当拒绝对组织运营、组织资产等造成有限的不良影响。	• 保密：非授权用户获取业务数据对组织运营、组织资产等造成严重的不良影响。 • 完整：业务数据被非法授权修改和破坏对组织运营、组织资产等造成严重的不良影响。 • 可用：合法用户使用业务数据被不正当拒绝对组织运营、组织资产等造成严重的不良影响。	• 保密：非授权用户获取业务数据对组织运营、组织资产等造成灾难性的不良影响。 • 完整：业务数据被非法授权修改和破坏对组织运营、组织资产等造成灾难性的不良影响。 • 可用：合法用户使用业务数据被不正当拒绝对组织运营、组织资产等造成灾难性的不良影响。

企业可基于上述公共分类、分级策略，结合自身业务、合规需求实际，规划出自己的数据分类分级方法，建立组织/公司自己的数据分类分级原则和方法，将数据按照重要程度进行分类，然后在数据分类的基础上根据数据安全在受到破坏后，对组织造成的影响和损失进行分级。

数据分级表

分级	名称	类别	举例
L2	二级数据	L2.1密码信息	登录密码、支付密码、取款密码、密码提示问题答案等
		L2.2非生物认证信息	法定证件图片（如身份证图片）、有效期内的身份验证Token/凭证等
		L2.3生物认证信息	虹膜、耳纹、掌纹、静脉、指纹、人脸、声纹、眼纹、步态、笔迹等
		L2.4银行卡相关数据	银行卡的CVV、有效期、PIN码、磁道信息等
		L2.5联系信息	手机号、电话号、详细地址、姓名、社交网络账号、邮箱、地址簿等
		L2.6唯一识别信息	法定证件（如身份证、护照、驾驶证等）号码及有效期限
		L2.7账户信息	账号和卡号、账户开立时间、开户行、账户余额、账户交易情况等
L1	一级数据	L1.1推演性凭证信息	替代账号、卡号的标记化Token凭证等
		L1.2个人基本信息	性别、国籍、民族、职业、婚姻状况、家庭状况、住所或工作单位地址及照片等
		L1.3个人金融交易信息	支付记录、金融相关浏览记录、贷款记录、信用卡使用记录等
		L1.4个人信用信息	信用卡还款情况、贷款偿还情况以及个人在经济活动中形成的、能够反映其信用状况的其他信息等
		L1.5个人财产信息	个人收入状况、拥有的不动产状况、拥有的车辆状况、纳税额、公积金缴存金额等
		L1.6衍生信息	对个人消费习惯、投资意愿、支付习惯等原始信息进行处理、分析所形成的反映特定个人某些情况的信息
		L1.7个人网络环境信息	客户端IP、MAC、IMEI、IMSI、Wi-Fi、地理位置定位等
L0	零级数据	L0.1社交信息	昵称、签名档、社交网络头像等
		L0.2脱敏的信息	只展示前3后4的手机号、前4后2的身份证号等

（企业自主分类分级示例）

在进行数据分类分级后需要有针对性地制定数据防护要求，设置不同的访问权限、对重要数据进行加密存储和传输、敏感数据进行脱敏处理、重要操作进行审计记录和分析等。

3) 变更审核

在进行分类分级工作中要明确相关内容和操作流程的审核和审批机制，保证数据分类分级工作符合组织的分类分级原则和制度要求。原则上已被明确分类分级的数据，其分级只可升级不可降级（防止泄密），审批需多人控制，涉及数据所有者、数据分类分级管理者，行者管理者等。

4) 技术工具简述

数据分类分级技术工具实现落地的前提是确定了组织内部的数据分类分级方法和策略，也就是分类和分级的规则。技术层面看，数据分类分级首先涉及到最初的数据发现，目前数据类型可以分为两种，一种是结构化的数据，如业务数据、数据库等；另外一种则是非结构化的数据，如商业文件、财务报表、合同等，依据标签库、关键词、正则表达式、自然语言处理、数据挖掘、机器学习等内容识别技术，进行数据分类，根据数据分类的结果，依据标签进行敏感数据的划分，最终实现数据分级的效果。

按元数据类型分类技术：

内容感知分类技术，对非结构化数据内容的自动分析来确定分类，涉及正则表达式、完全匹配、部分或完整指纹识别、机器学习等。

情境感知分类技术，基于数据特定属性类型，利用广泛上下文属性，适用于静态数据（如基

于存储路径或其他文件元数据)、使用中的数据(如由 CAD 应用程序创建的数据)和传输中的数据(基于 IP)。

按实际应用场景分类技术:

根据分类分级规则,建立标签库,利用机器学习算法经过训练形成分类器,利用分类器将生成的分类器应用在有待分类的文档集合中,获取文档的分类结果,并可进行自动化打标。

受限于篇幅,此处技术工具不进行进一步展开,下图为数据分级分类的技术工具进行分类分级作业的基本流程图。

